Short Paper: Toward Practical Post-Quantum Secure Boot: Lessons from Resource-Constrained Deployment

Jefferson Ricardini
Amazon
São Paulo, Brazil
jricardi@amazon.com

Abstract

This paper presents practical insights and a methodology for deploying post-quantum cryptography in secure boot for hardware-constrained environments. Our study shows that implementing NIST's post-quantum cryptography standards presents significant practical challenges, particularly for resource-constrained embedded devices that must maintain standards compliance beyond the traditional cryptography deprecation period (2030-2035). We describe the selection criteria and trade-offs that led to choosing ML-DSA over alternatives and the implementation approaches that balance security requirements with practical deployment constraints. Our key learnings are: memory constraints significantly affect algorithm selection, architectural decisions require careful security-performance balance, and hardware acceleration requirements determine deployment viability. This work provides practical deployment insights for security engineers and identifies critical research gaps needed to support successful post-quantum cryptography transition in embedded systems.

CCS Concepts

• **Security and privacy → Digital signatures**.

Keywords

Secure-boot; Digital signatures; Post-quantum

ACM Reference Format:
Jefferson Ricardini. 2025. Short Paper: Toward Practical Post-Quantum Secure Boot: Lessons from Resource-Constrained Deployment. In *Proceedings of the 2025 Workshop on Quantum-Resistant Cryptography and Security (QRSEC '25), October 13–17, 2025, Taipei, Taiwan.* ACM, New York, NY, USA, 5 pages. https://doi.org/10.1145/3733820.3767142

1 Introduction

While NIST's 2024 publication of post-quantum cryptography (PQC) algorithms established theoretical foundations, there is a methodological gap between these standards and practical implementation in resource-constrained environments. This paper presents a systematic analysis of ML-DSA [11] secure boot deployment in embedded systems with strict memory and processing limitations, where the hardware must maintain standards compliance beyond the traditional cryptography deprecation period (2030-2035) [13]. This research provides a structured framework for navigating the complex trade-offs between security requirements, performance constraints, and practical deployment realities.

From our deployment experience, we identified several critical insights. Our key findings show that algorithm selection involves a complex trade-off analysis beyond security properties alone. The analysis revealed how memory limitations directly affect parameter choices, and hardware supplier capabilities create unexpected practical barriers. For example, some HSM vendors lacked support for certain algorithms due to missing test vectors, affecting selection independent of security considerations – a constraint not addressed in theoretical standards.

We present the research findings as a systematic methodology that practitioners can apply to their own post-quantum implementations. The work provides a structured decision-making framework grounded in empirical analysis and real-world constraints. Our contribution bridges the critical gap between theoretical standards and practical implementation through documented methodology, constraint analysis, and validated deployment strategies.

We organize the paper as follows: Section 2 presents our algorithm selection methodology. Section 3 examines implementation trade-offs and architectural decisions. Section 4 discusses deployment lessons for the community. Section 5 concludes with the identification of research gaps that emerged from our experience.

2 Algorithm Selection Methodology

Selecting post-quantum algorithms for secure boot requires systematic evaluation beyond theoretical security properties. Our investigation revealed that practical constraints often override theoretical preferences, necessitating a structured decision framework that accounts for real-world limitations.

2.1 Four-Dimensional Evaluation Framework

To address complex inter-dependencies among implementation factors, we developed a four-dimensional evaluation matrix enabling systematic quantification of trade-offs:

Security: NIST security categories and standardization status determined baseline requirements. NIST Category 5 provides maximum security, while Category 2 offers adequate protection with reduced resources [13]. Standardization proved critical – algorithms without FIPS approval may risk creating compliance complications.

Resources: Memory footprint and storage requirements created hard boundaries. Combined signature and public key sizes directly affect ROM allocation and firmware updates, proved the selection more restrictive than anticipated.

This work is licensed under a Creative Commons Attribution 4.0 International License.
QRSEC '25, Taipei, Taiwan
© 2025 Copyright held by the owner/author(s).
ACM ISBN 979-8-4007-1908-0/25/10
https://doi.org/10.1145/3733820.3767142

Performance: Verification speed and hardware acceleration availability determined deployment feasibility. Software-only post-quantum implementations impose significant boot time penalties, making hardware acceleration necessary rather than optional.

Compatibility: Infrastructure support and supplier capabilities emerged as decisive factors. HSM vendor support and existing signing infrastructure compatibility often determined algorithm viability independent of other considerations.

2.2 Algorithm Analysis and Selection

Applying this framework revealed distinct trade-off profiles for each candidate:

ML-DSA – CRYSTALS-Dilithium [3, 11]: Demonstrated strong security through FIPS 204 standardization with available hardware acceleration, but required significant resources (7,219 bytes for ML-DSA-87) while offering comprehensive HSM vendor support.

SLH-DSA – SPHINCS$^+$ [2, 12]: Provided equivalent security level with a stronger theoretical security foundation. However presented excessive resource requirements (≈ 30KB signatures) that exceeded practical deployment boundaries for embedded devices.

NIST SP 800-208 – XMSS/LMS [6, 8, 10]: Offered strong theoretical security with efficient verification and optimal resource usage (XMSS [6]: 64-byte keys, 2.5KB signatures), but faced HSM support limitations preventing FIPS validation in regards to private key state management.

This systematic evaluation led to selecting ML-DSA despite XMSS's superior resource profile, demonstrating how infrastructure compatibility constraints often override theoretical preferences. The selection informed our architectural strategy, leading to an implementation approach that balances security and practicality. Section 3 provides detailed analysis of this architectural approach, including security implications and implementation trade-offs.

Organizations can adapt this framework by systematically cataloging their hard constraints-memory boundaries, HSM capabilities, compliance requirements-before algorithm evaluation. Our analysis indicates compatibility assessment should occur early, as infrastructure limitations can eliminate otherwise attractive options regardless of their technical merits.

3 Implementation Trade-offs and Design Decisions

After selecting ML-DSA, the implementation decisions proved more complex than algorithm selection itself, requiring trade-offs across security, performance, and operational constraints.

3.1 Implementation Architecture

We evaluated three approaches: hybrid (simultaneous verification), dual (switchable), and PQ-only. Each approach presents distinct trade-offs across security, performance, implementation complexity and storage dimensions that significantly impact deployment feasibility.

Hybrid Implementation: Requires simultaneous verification of traditional and post-quantum signatures during every boot, providing the highest security confidence by leveraging strengths of both cryptographic approaches. traditional algorithms (ECDSA) benefit from decades of cryptographic analysis and are resilient to non-quantum attacks, while post-quantum algorithms (ML-DSA) provide protection against future quantum threats but is relatively new. This dual protection ensures the system remains secure even if vulnerabilities emerge in either scheme type.

However, hybrid implementation incurs the highest performance cost, requiring verification of two signatures for each firmware component and extending overall boot time. This approach also demands the most storage resources, requiring two sets of verification code and two sets of public keys on the device. Domain separation requirements create additional complexity when combining traditional algorithms (typically without domain separation) with post-quantum schemes that incorporate domain separators either before or after hashing operations [1]. For devices with single hash engines, this may require engine state resets, further impacting boot performance.

Dual Implementation: The mutable boot strategy stores both verification capabilities but activates only one based on OTP (One-Time Programmable) configuration bits. This provides optimal performance during the transition period while maintaining quantum-readiness for future activation. Initially, the system can use traditional signatures (ECDSA) to meet current performance requirements, then transitions to post-quantum verification (ML-DSA) when quantum threats become imminent by setting OTP bits to enable post-quantum mode.

The dual approach addresses performance concerns by avoiding the computational overhead of simultaneous verification, but still requires storage for both algorithm implementations and key sets. The transition timing becomes a critical business decision that must balance quantum threat assessment against performance requirements.

PQ-Only: Offers implementation simplicity and reduced ROM requirements by eliminating traditional algorithm support entirely. This approach provides consistent performance characteristics and the smallest storage footprint, requiring only one set of verification code and public keys.

However, PQ-only carries significant risk for devices with 7-15 year operational lifespans. Post-quantum algorithms, while designed to resist quantum attacks, have not undergone the same decades of cryptographic analysis as traditional schemes. Historical precedent shows cryptographic algorithms often require key size adjustments as analysis progresses – RSA key sizes evolved from 512 bits (1977) to 2048+ bits as computational capabilities advanced [14]. Similar revisions to post-quantum parameters may occur, potentially at an accelerated pace. Without fallback mechanisms, devices using PQ-only implementation become vulnerable if implementation flaws emerge or algorithm recommendations change during their operational lifetime.

Mixed Architecture Strategy: Secure boot implementation involves bootstrapping through multiple stages with different characteristics and security requirements. Our analysis led to a mixed approach that optimizes security-performance trade-offs for each boot stage:

- **Early Boot Stages (ROM-based, Immutable)**: Typically stored in ROM or other immutable storage and cannot be modified after device deployment, making them permanent components of the device's security foundation. For these

2

stages, we choose hybrid verification despite the performance impact, as they require the strongest security guarantees and must remain secure throughout the entire device lifecycle. The performance cost is acceptable for these early boot stages, and the dual protection ensures long-term security even if vulnerabilities emerge in either cryptographic approach.

- **Later Boot Stages (Flash-based, Updatable)**: Typically stored in updatable flash memory and support post deployment updates, enabling security evolution as threats develop. For updatable stages, we implement dual verification to optimize performance while maintaining upgrade capability. Since these stages can be updated, they can transition to post-quantum signatures when quantum threats materialize while maintaining optimal boot performance until transition becomes necessary.

This mixed strategy balances the immutable nature of early boot stages (requiring maximum security through hybrid implementation) against the performance flexibility needs of updatable stages (using dual implementation). The approach recognizes that different boot components have varying security requirements and update capabilities, enabling tailored security strategies rather than uniform implementation across all stages.

The mixed approach emerged from recognizing that boot stages have fundamentally different characteristics requiring different security strategies. Immutable stages demand maximum protection through hybrid verification, while updatable stages benefit from the performance optimization and upgrade flexibility of dual implementation. This strategy provides the highest practical security while maintaining acceptable boot performance and operational flexibility for managing the post-quantum transition timing.

3.2 Chain of Trust Architecture

Independent Chain of Trust: Maintains separate verification paths for traditional and post-quantum signatures using standard X.509 certificate formats [5]. This approach integrates seamlessly with existing certificate management infrastructure and enables independent algorithm updates, supporting crypto-agility [4] when vulnerabilities emerge in either scheme. The architecture provides clear certification paths for compliance frameworks and leverages proven certificate management workflows. However, it requires increased storage for dual certificates and introduces verification complexity requiring coordination between separate chains, particularly for handling partial failure scenarios.

Single Chain with Combined Certificates: Embeds both signature types within unified certificates, creating a more storage-efficient approach that reduces certificate handling overhead and streamlines verification flow. This architecture potentially improves boot performance by processing both signatures within a single certificate operation and simplifies certificate distribution mechanisms. However, it requires custom certificate formats extending beyond standard X.509 specifications, creating parsing complexity and potential compatibility issues. Future algorithm updates become more challenging as changes to either signature type may require certificate format modifications, complicating crypto-agility.

We selected independent chain architecture to prioritize compatibility with existing infrastructure while maintaining flexibility for cryptographic evolution. The approach reduces implementation risk by leveraging proven certificate systems and standard formats, avoiding custom parsing logic that could introduce vulnerabilities. The architecture maintains operational flexibility through independent lifecycle management while ensuring standards compliance and regulatory framework compatibility.

3.3 Hardware Acceleration

Software-only ML-DSA verification creates significant boot time penalties, making hardware acceleration essential rather than optional for production deployment. Our analysis revealed that ML-DSA's computational complexity stems from two primary operations: SHAKE hashing functions and Number Theoretic Transform (NTT) operations, each presenting different acceleration opportunities and trade-offs.

SHAKE Function Acceleration: ML-DSA relies heavily on SHAKE (Secure Hash Algorithm with Keccak) [9] for various internal operations including key generation, signing, and verification processes. SHAKE operations can consume approximately 60-70% of ML-DSA's total computation time depending on the architecture [7], making hash function acceleration the highest-impact optimization target. Generic hash accelerators supporting SHAKE/SHA3 can provide substantial ML-DSA performance improvements while maintaining flexibility for other cryptographic operations. This approach offers excellent hardware efficiency since SHAKE accelerators support multiple algorithms beyond ML-DSA.

NTT Operation Acceleration: The Number Theoretic Transform represents ML-DSA's second computational bottleneck. Dedicated NTT acceleration provides additional performance gains but requires specialized hardware logic specifically designed for lattice cryptography. NTT accelerators would consume a significant silicon area for a lattice-dedicated operation, in comparison with hash accelerators that can serve multiple purposes beyond just Lattices.

Implementation Approach: We prioritized SHAKE acceleration as the primary hardware acceleration target due to its favorable performance-to-cost ratio. This approach provides the majority of available performance benefits while maintaining reasonable hardware requirements. For devices with sufficient silicon budget, NTT acceleration can be added as a secondary optimization, but SHAKE acceleration alone provides acceptable boot time performance for most deployment scenarios.

Multiple vendors offer various acceleration approaches, from generic hash accelerators to full ML-DSA implementation cores. Our implementation strategy includes software fallback capabilities to ensure functionality even when hardware acceleration is unavailable, though performance targets assume SHAKE acceleration availability as a minimum requirement.

4 Lessons Learned

Our ML-DSA deployment revealed that the biggest challenges emerged during integration, often requiring fundamental changes to decisions that seemed straightforward during planning. These lessons provide actionable guidance for organizations navigating similar transitions.

4.1 Memory and Resource Constraints

Our most significant deployment challenge involved memory constraints that forced fundamental algorithm parameter changes late in implementation. Initial planning selected ML-DSA-87 for maximum security, but integration testing revealed runtime memory requirements of 91KB, far exceeding our target platform capabilities. Resource constraints forced algorithm parameter changes from ML-DSA-87 to ML-DSA-44, representing a security reduction driven by memory limitations rather than cryptographic considerations. Subsequent memory optimization efforts enabled returning to ML-DSA-87 following stack optimization from [7], reducing peak memory usage from 91KB to acceptable levels, but this iterative process consumed significant development time and created program management complications.

Key Lesson: Memory analysis must occur early using actual target hardware rather than theoretical specifications. Static algorithm specifications consistently underestimated real-world requirements by significant margins. Peak memory usage during verification operations, temporary storage requirements, and stack usage patterns all exceeded theoretical specifications. We developed memory profiling techniques that measure peak usage during signature verification operations, revealing optimization opportunities and resource conflicts that emerge only during hardware integration testing.

4.2 Infrastructure and Vendor Compatibility

HSM vendor limitations created unexpected deployment blockers that emerged only during detailed implementation planning. Our preferred XMSS algorithm became unavailable due to HSM vendor lack of support with proper private key state management. This infrastructure limitation overrode technical algorithm preferences and forced architectural changes. HSM capabilities, certificate management system support, and tool-chain compatibility often become critical path limitations that override algorithm preferences.

Key Lesson: Conduct detailed vendor compatibility assessments before finalizing algorithm selections. We recommend creating vendor capability matrices that document specific algorithm support, validation status, and roadmap commitments. These assessments should include vendor capability verification, standard compliance validation, and integration testing with existing systems, occurring before algorithm selection finalization to avoid late-stage architectural changes.

4.3 Performance and Hardware Integration

Performance testing revealed substantial impact of software-only post-quantum verification on boot time requirements. ML-DSA-87 verification required 34ms compared to 3ms for hardware-accelerated ECDSA – a performance penalty that approached system timing constraints. This discovery drove hardware acceleration requirements that affected SoC design decisions and procurement timelines. ML-DSA hardware IP acquisition introduced procurement and integration timelines that significantly exceeded initial estimates, creating critical path dependencies threatening deployment schedules.

Key Lesson: Performance evaluation must occur in realistic system contexts rather than isolated benchmarks. Boot time constraints, user experience requirements, and system timing dependencies create performance boundaries not apparent in algorithm-focused analysis. Begin hardware acceleration planning early, as procurement timelines often exceed algorithm development efforts.

4.4 Implementation Complexity and Coordination

Choosing between hybrid, dual, and PQ-only approaches involved intricate considerations around certificate management, parsing requirements, and failure handling that weren't apparent initially. X.509 integration revealed substantial parsing and verification complexity that standard documentation doesn't adequately address. The hybrid approach required solving domain separation challenges when combining traditional algorithms with post-quantum schemes, creating performance implications not apparent in architectural planning.

Post-quantum cryptography deployment requires coordination across multiple organizational boundaries (cryptography teams, hardware development, procurement, and operations) with interdependencies that are not immediately apparent. RTL freeze deadlines, hardware supplier schedules, and certification timelines create coordination challenges that affect implementation feasibility.

Key Lesson: Architectural decisions often have longer-lasting impact than algorithm choices, determining operational flexibility throughout device lifecycle. Successful deployments require explicit timeline coordination that accounts for external dependencies and procurement lead times. Create detailed dependency mapping that identifies critical path items across organizational boundaries.

5 Conclusion

Our ML-DSA secure boot deployment demonstrates that organizations can successfully implement post-quantum cryptography in resource-constrained environments using systematic decision-making approaches. The four-dimensional evaluation framework (security, performance, resources, compatibility) we developed navigated complex real-world constraints to achieve practical quantum-resistant secure boot while revealing critical gaps between academic research and implementation needs.

Our mixed architecture approach proved essential for balancing security and performance requirements, implementing hybrid verification for immutable boot stages and dual verification for mutable stages. The dual chain of trust architecture enabled standards compliance while avoiding custom certificate format complexity. Performance measurements validated our approach: ML-DSA verification completed in 34ms compared to 3ms for hardware-accelerated ECDSA, remaining within boot time requirements through SHAKE acceleration.

The deployment revealed four critical challenge categories: memory constraints require early profiling on target hardware, infrastructure compatibility often overrides theoretical preferences, performance integration demands system-context evaluation, and implementation complexity requires cross-organizational coordination. Our eight-month timeline from algorithm selection through

working hardware provides realistic planning guidance for similar deployments.

Critical research opportunities emerged where academic work could significantly support industry adoption: algorithm variants optimized for deployment constraints, formal frameworks for post-quantum deployment decision-making under real-world constraints, and tiered acceleration strategies balancing silicon area against performance gains for embedded implementations.

Organizations beginning post-quantum planning can apply our four-dimensional evaluation framework across different embedded device classes, adapting constraint priorities to their contexts. The memory optimization strategies, dual chain of trust architecture, and infrastructure compatibility assessment methodology provide proven templates while our lessons learned guide navigation of memory constraints, vendor compatibility, performance integration, and coordination challenges. This systematic methodology offers implementers a structured approach for post-quantum transition while identifying research opportunities that could significantly ease industry adoption of quantum-resistant cryptography.

References

[1] Martin R. Albrecht, Sofía Celi, Benjamin Dowling, and Daniel Jones. 2023. Practically-exploitable Cryptographic Vulnerabilities in Matrix. In *2023 IEEE Symposium on Security and Privacy (SP)*. IEEE Computer Society Conference Publishing Services, San Francisco, CA, 164–181. doi:10.1109/SP46215.2023.10351027

[2] Daniel J. Bernstein, Andreas Hülsing, Stefan Kölbl, Ruben Niederhagen, Joost Rijneveld, and Peter Schwabe. 2019. The SPHINCS+ Signature Framework. In *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security* (London, United Kingdom) *(CCS '19)*. Association for Computing Machinery, New York, NY, USA, 2129–2146. doi:10.1145/3319535.3363229

[3] Léo Ducas, Eike Kiltz, Tancrède Lepoint, Vadim Lyubashevsky, Peter Schwabe, Gregor Seiler, and Damien Stehlé. 2018. CRYSTALS-Dilithium: A Lattice-Based Digital Signature Scheme. *IACR Transactions on Cryptographic Hardware and Embedded Systems* 2018, 1 (2018), 238–268. doi:10.13154/tches.v2018.i1.238-268

[4] Olaf Grote, Andreas Ahrens, and César Benavente-Peces. 2019. A Review of Post-quantum Cryptography and Crypto-agility Strategies. In *2019 International Interdisciplinary PhD Workshop (IIPhDW)*. Institute of Electrical and Electronics Engineers (IEEE), Wismar, Germany, 115–120. doi:10.1109/IIPHDW.2019.8755433

[5] Russ Housley, Tim Polk, Dr. Warwick S. Ford, and Dave Solo. 1999. Internet X.509 Public Key Infrastructure Certificate and CRL Profile. RFC 2459. doi:10.17487/RFC2459

[6] Andreas Huelsing, Denis Butin, Stefan-Lukas Gazdag, Joost Rijneveld, and Aziz Mohaisen. 2018. XMSS: eXtended Merkle Signature Scheme. RFC 8391. doi:10.17487/RFC8391

[7] Matthias J. Kannwischer. 2025. mupq – pqm4. https://github.com/mupq/pqm4/blob/50e597540e0811478b8b13dcc24d708b89521c78/benchmarks.md.

[8] David McGrew, Michael Curcio, and Scott Fluhrer. 2019. Leighton-Micali Hash-Based Signatures. RFC 8554. doi:10.17487/RFC8554

[9] National Institute of Standards and Technology. 2015. *SHA-3 Standard: Permutation-Based Hash and Extendable-Output Functions.* Federal Information Processing Standards Publication FIPS 202. National Institute of Standards and Technology. https://csrc.nist.gov/pubs/fips/202/final

[10] National Institute of Standards and Technology. 2020. *Recommendation for Stateful Hash-Based Signature Schemes.* National Institute of Standards and Technology Special Publication NIST SP 800-208. National Institute of Standards and Technology. https://csrc.nist.gov/pubs/sp/800/208/final

[11] National Institute of Standards and Technology. 2024. *Module-Lattice-Based Digital Signature Standard.* Federal Information Processing Standards Publication FIPS 204. National Institute of Standards and Technology. https://csrc.nist.gov/pubs/fips/204/final

[12] National Institute of Standards and Technology. 2024. *Stateless Hash-Based Digital Signature Standard.* Federal Information Processing Standards Publication FIPS 205. National Institute of Standards and Technology. https://csrc.nist.gov/pubs/fips/205/final

[13] National Institute of Standards and Technology. 2024. *Transition to Post-Quantum Cryptography Standards.* National Institute of Standards and Technology Internal Report NIST IR 8547. National Institute of Standards and Technology. https://csrc.nist.gov/pubs/ir/8547/ipd initial draft.

[14] Nigel P. Smart and Emmanuel Thome. 2021. History of Cryptographic Key Sizes. Cryptology ePrint Archive, Paper 2021/894. https://eprint.iacr.org/2021/894